НАО «КАРАГАНДИНСКИЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ ИМЕНИ АБЫЛКАСА САГИНОВА»

Кафедра Кибербезопасности и искусственного интеллекта

Лабораторная работа № 5

по дисциплине «Безопасность Баз данных»

Тема:«Аудит действий пользователей в Microsoft SQL Server с помощью SQL Server Audit»

Специальность: 6В06301 – «Системы информационной безопасности»

Принял: ст.преп.
Жакина М.М.
Выполнил:
СИБ 23-7 Гутникевич Е.А.

Караганда 2026

Структура SQL Server Audit
SQL Server Audit состоит из двух частей:
1. SQL Server Audit — определяет, куда записывать события.
2. Audit Specification — определяет, какие именно события записывать.
События можно сохранять:
в файл;
в журнал приложений Windows;
в журнал безопасности Windows.
В лабораторной работе будет использоваться запись в файл.

Подготовка среды
Создайте тестовую базу данных:

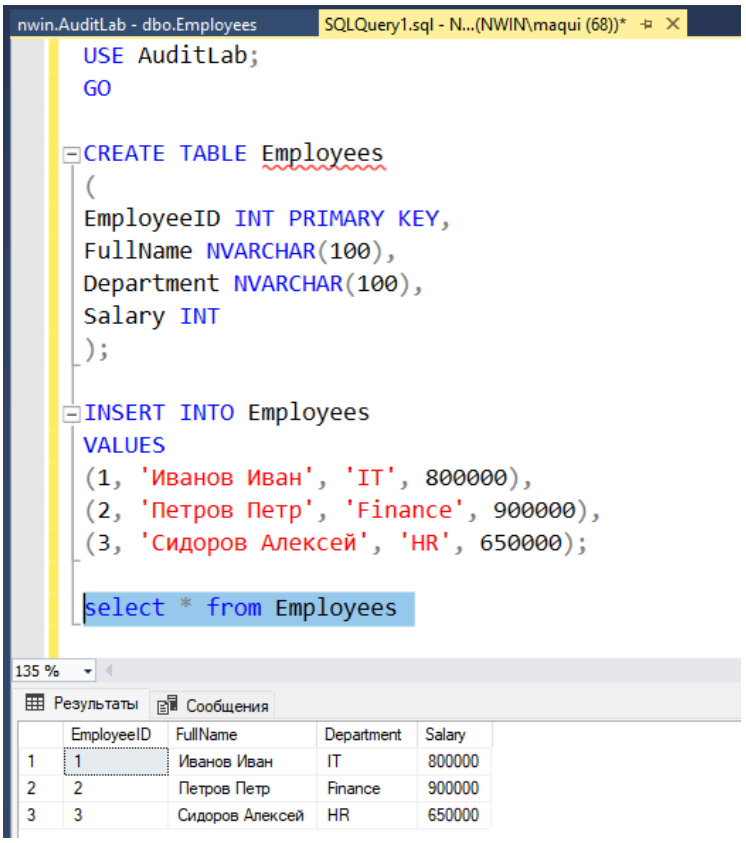
```
CREATE DATABASE AuditLab;
GO
USE AuditLab;
GO
```

Создайте таблицу:

```
CREATE TABLE Employees
(
EmployeeID INT PRIMARY KEY,
FullName NVARCHAR(100),
Department NVARCHAR(100),
Salary INT
);
```

Добавьте тестовые данные:

```
INSERT INTO Employees
VALUES
(1, 'Иванов Иван', 'IT', 800000),
(2, 'Петров Петр', 'Finance', 900000),
(3, 'Сидоров Алексей', 'HR', 650000);
```



Часть 1. Создание SQL Server Audit

Создайте папку для хранения файлов аудита, например:

C:\SQLAudit\

Создайте аудит:

```
USE master;
GO
CREATE SERVER AUDIT Audit_UserActions
TO FILE
(
FILEPATH = 'C:\SQLAudit\',
MAXSIZE = 100 MB,
MAX_ROLLOVER_FILES = 10,
RESERVE_DISK_SPACE = OFF
);
GO
```

Включите аудит:

```
ALTER SERVER AUDIT Audit_UserActions
WITH (STATE = ON);
GO
```

```sql
USE master;
GO
CREATE SERVER AUDIT Audit_UserActions
TO FILE
(
FILEPATH = 'C:\Users\maqui\Downloads\auditesting',
MAXSIZE = 100 MB,
MAX_ROLLOVER_FILES = 10,
RESERVE_DISK_SPACE = OFF
);
GO

ALTER SERVER AUDIT Audit_UserActions
WITH (STATE = ON);
GO
```

```
Сообщения
Выполнение команд успешно завершено.

Время выполнения: 2026-04-10T20:14:57.1860892+05:00
```

Часть 2. Создание Server Audit Specification

Создайте спецификацию для отслеживания входов и ошибок входа:

CREATE SERVER AUDIT SPECIFICATION Audit_LoginEvents
FOR SERVER AUDIT Audit_UserActions
ADD (SUCCESSFUL_LOGIN_GROUP),
ADD (FAILED_LOGIN_GROUP),
ADD (LOGOUT_GROUP)
WITH (STATE = ON);
GO

Теперь SQL Server будет фиксировать:

успешные входы;

неудачные входы;

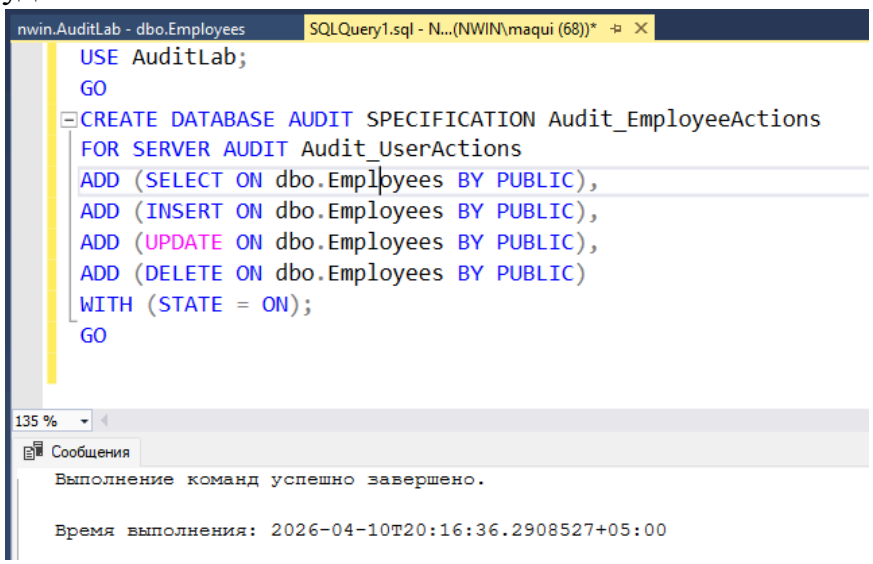
выходы пользователей.

```sql
CREATE SERVER AUDIT SPECIFICATION Audit_LoginEvents
FOR SERVER AUDIT Audit_UserActions
ADD (SUCCESSFUL_LOGIN_GROUP),
ADD (FAILED_LOGIN_GROUP),
ADD (LOGOUT_GROUP)
WITH (STATE = ON);
GO
```

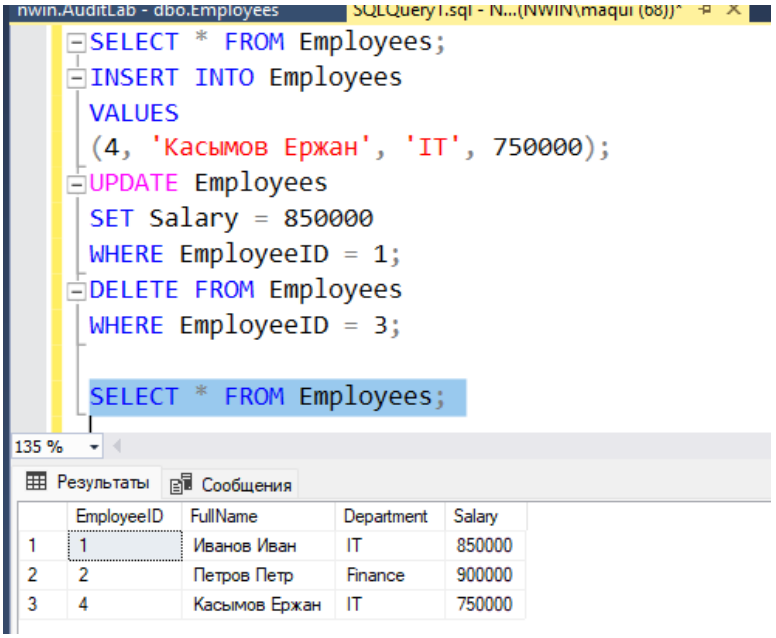
```
Сообщения
Выполнение команд успешно завершено.

Время выполнения: 2026-04-10T20:15:36.0353631+05:00
```

Часть 3. Создание Database Audit Specification
Перейдите в базу AuditLab:
USE AuditLab;
GO
Создайте спецификацию:
CREATE DATABASE AUDIT SPECIFICATION Audit_EmployeeActions
FOR SERVER AUDIT Audit_UserActions
ADD (SELECT ON dbo.Employees BY PUBLIC),
ADD (INSERT ON dbo.Employees BY PUBLIC),
ADD (UPDATE ON dbo.Employees BY PUBLIC),
ADD (DELETE ON dbo.Employees BY PUBLIC)
WITH (STATE = ON);
GO
Теперь аудит будет фиксировать:
чтение данных;
добавление записей;
изменение записей;
удаление записей.



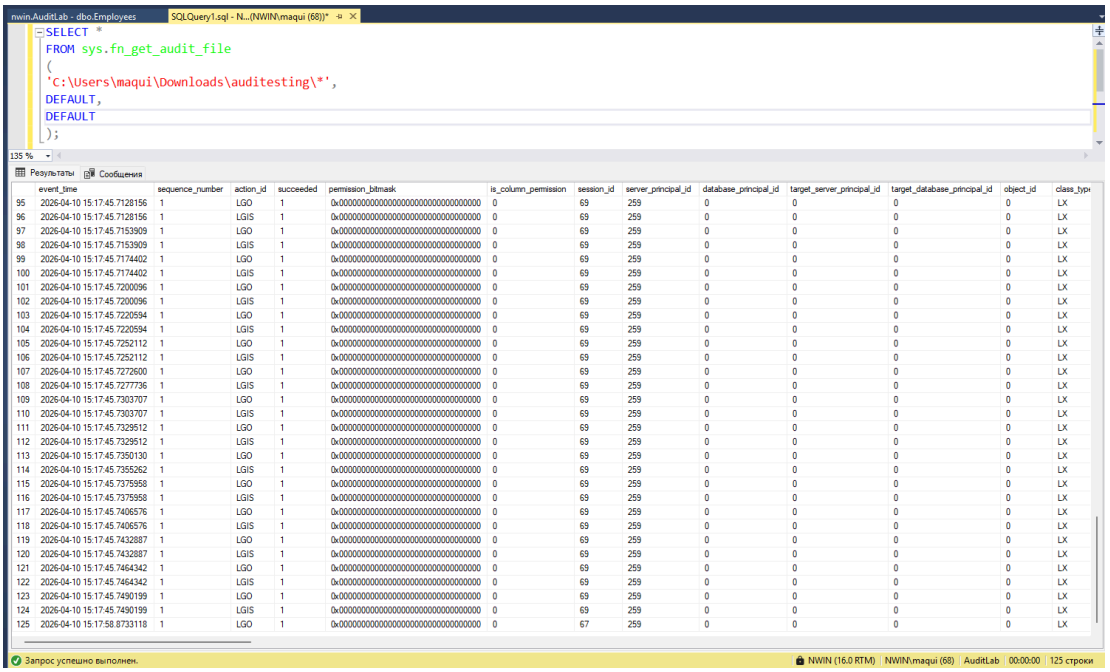
Часть 4. Генерация событий
Выполните несколько действий:
SELECT * FROM Employees;
INSERT INTO Employees
VALUES
(4, 'Касымов Ержан', 'IT', 750000);
UPDATE Employees
SET Salary = 850000
WHERE EmployeeID = 1;
DELETE FROM Employees
WHERE EmployeeID = 3;



Часть 5. Просмотр результатов аудита
Для просмотра используйте функцию:

```
SELECT *
FROM sys.fn_get_audit_file
(
'C:\SQLAudit\*',
DEFAULT,
DEFAULT
);
```

Полезные поля:
event_time;
action_id;
succeeded;
session_server_principal_name;
database_name;
object_name;
statement;
server_principal_name;
client_ip.



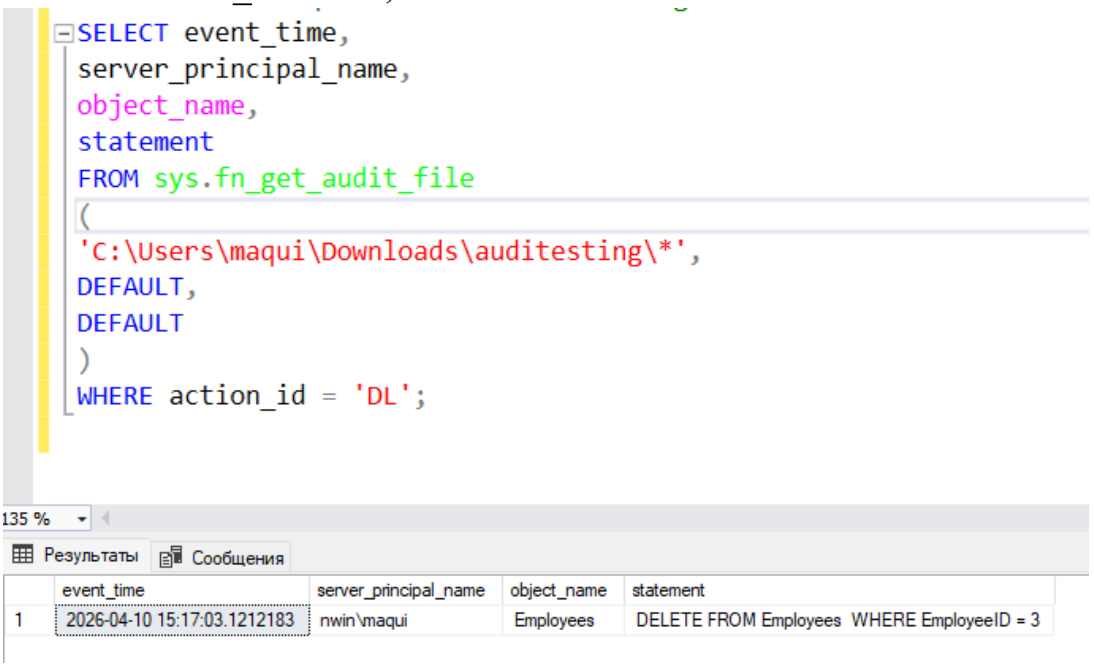
```
SELECT *
FROM sys.fn_get_audit_file
(
'C:\Users\maqui\Downloads\auditesting\*',
DEFAULT,
DEFAULT
);
```

	event_time	sequence_number	action_id	succeeded	permission_bitmask	is_column_permission	session_id	server_principal_id	database_principal_id	target_server_principal_id	target_database_principal_id	object_id	class_type
95	2026-04-10 15:17:45.7128156	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
96	2026-04-10 15:17:45.7128156	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
97	2026-04-10 15:17:45.7153909	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
98	2026-04-10 15:17:45.7153909	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
99	2026-04-10 15:17:45.7174402	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
100	2026-04-10 15:17:45.7174402	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
101	2026-04-10 15:17:45.7200096	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
102	2026-04-10 15:17:45.7200096	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
103	2026-04-10 15:17:45.7220594	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
104	2026-04-10 15:17:45.7220594	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
105	2026-04-10 15:17:45.7252112	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
106	2026-04-10 15:17:45.7252112	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
107	2026-04-10 15:17:45.7272600	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
108	2026-04-10 15:17:45.7277736	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
109	2026-04-10 15:17:45.7303707	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
110	2026-04-10 15:17:45.7303707	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
111	2026-04-10 15:17:45.7329512	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
112	2026-04-10 15:17:45.7329512	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
113	2026-04-10 15:17:45.7350130	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
114	2026-04-10 15:17:45.7355262	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
115	2026-04-10 15:17:45.7375958	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
116	2026-04-10 15:17:45.7375958	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
117	2026-04-10 15:17:45.7406576	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
118	2026-04-10 15:17:45.7406576	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
119	2026-04-10 15:17:45.7432887	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
120	2026-04-10 15:17:45.7432887	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
121	2026-04-10 15:17:45.7464342	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
122	2026-04-10 15:17:45.7464342	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
123	2026-04-10 15:17:45.7490199	1	LGO	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
124	2026-04-10 15:17:45.7490199	1	LGIS	1	0x0000000000000000000000000000000000	0	69	259	0	0	0	0	LX
125	2026-04-10 15:17:58.8733118	1	LGO	1	0x0000000000000000000000000000000000	0	67	259	0	0	0	0	LX

Часть 6. Поиск подозрительных действий

Поиск удалений

SELECT event_time,
server_principal_name,
object_name,
statement
FROM sys.fn_get_audit_file
(
'C:\SQLAudit*',
DEFAULT,
DEFAULT
)
WHERE action_id = 'DL';



```
SELECT event_time,
server_principal_name,
object_name,
statement
FROM sys.fn_get_audit_file
(
'C:\Users\maqui\Downloads\auditesting\*',
DEFAULT,
DEFAULT
)
WHERE action_id = 'DL';
```

	event_time	server_principal_name	object_name	statement
1	2026-04-10 15:17:03.1212183	nwin\maqui	Employees	DELETE FROM Employees WHERE EmployeeID = 3

Поиск изменений зарплаты

```
SELECT event_time,
server_principal_name,
statement
FROM sys.fn_get_audit_file
(
'C:\SQLAudit\*',
DEFAULT,

DEFAULT
)
WHERE statement LIKE '%Salary%';
```

```
SELECT event_time,
server_principal_name,
statement
FROM sys.fn_get_audit_file
(
'C:\Users\maqui\Downloads\auditesting\*',
DEFAULT,

DEFAULT
)
WHERE statement LIKE '%Salary%';
```

135 %

Результаты | Сообщения

	event_time	server_principal_name	statement
1	2026-04-10 15:17:03.1212183	nwin\maqui	UPDATE Employees SET Salary = 850000 WHERE Emp...
2	2026-04-10 15:17:03.1212183	nwin\maqui	UPDATE Employees SET Salary = 850000 WHERE Emp...

Поиск неудачных входов

```
SELECT event_time,
server_principal_name,
succeeded,
statement
FROM sys.fn_get_audit_file
(
'C:\SQLAudit\*',
DEFAULT,
DEFAULT
)
WHERE action_id = 'LGIF';
```

```
SELECT event_time,
server_principal_name,
succeeded,
statement
FROM sys.fn_get_audit_file
(
'C:\Users\maqui\Downloads\auditesting\*',
DEFAULT,
DEFAULT
)
WHERE action_id = 'LGIF';
```

135 %

Результаты | Сообщения

event_time	server_principal_name	succeeded	statement

Поиск действий конкретного пользователя

```
SELECT event_time,
action_id,
object_name,
statement
FROM sys.fn_get_audit_file
(
'C:\SQLAudit\*',
DEFAULT,
DEFAULT
)
WHERE server_principal_name = 'TestUser';
```

```
SELECT event_time,
action_id,
object_name,
statement
FROM sys.fn_get_audit_file
(
'C:\Users\maqui\Downloads\auditesting\*',
DEFAULT,
DEFAULT
)
WHERE server_principal_name = 'TestUser';
```

135 %

Результаты | Сообщения

event_time	action_id	object_name	statement

Часть 7. Аудит изменения прав доступа
Создайте дополнительную спецификацию:

```
USE master;
GO
CREATE SERVER AUDIT SPECIFICATION Audit_PermissionChanges
FOR SERVER AUDIT Audit_UserActions
ADD (SERVER_ROLE_MEMBER_CHANGE_GROUP),
ADD (DATABASE_ROLE_MEMBER_CHANGE_GROUP),
ADD (DATABASE_PERMISSION_CHANGE_GROUP)

WITH (STATE = ON);
GO
```

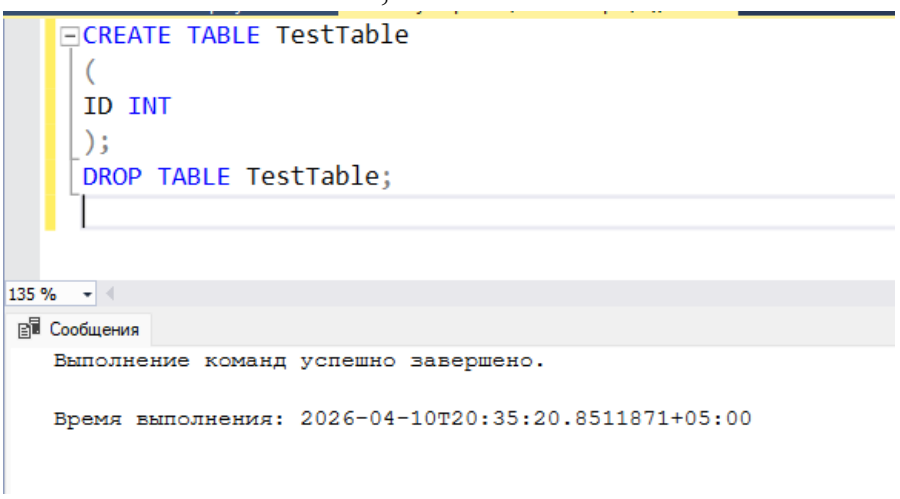
Теперь будут фиксироваться:
выдача прав;
отзыв прав;
добавление пользователей в роли.

Часть 8. Аудит создания и удаления объектов

```
USE AuditLab;
GO
CREATE DATABASE AUDIT SPECIFICATION Audit_ObjectChanges
FOR SERVER AUDIT Audit_UserActions
ADD (SCHEMA_OBJECT_CHANGE_GROUP)
WITH (STATE = ON);
GO
```

Проверьте:

```
CREATE TABLE TestTable
(
ID INT
);
DROP TABLE TestTable;
```



Часть 9. Отключение аудита

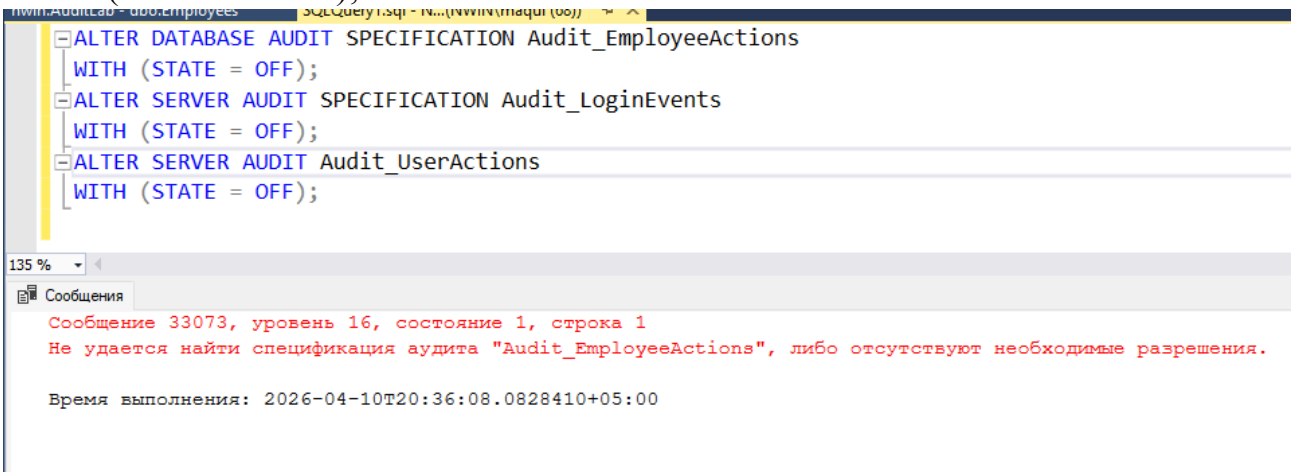
Отключение спецификаций:

ALTER DATABASE AUDIT SPECIFICATION Audit_EmployeeActions
WITH (STATE = OFF);

ALTER SERVER AUDIT SPECIFICATION Audit_LoginEvents
WITH (STATE = OFF);

Отключение самого аудита:

ALTER SERVER AUDIT Audit_UserActions
WITH (STATE = OFF);



Дополнительные задания

```
-- 1. ЗАДАНИЕ 1 & 2 & 3:
--    Расширенный триггерный аудит ТОЛЬКО таблицы Melts,
--    ТОЛЬКО для ролей OperatorRole и AdminChem,
--    ТОЛЬКО операций DELETE и UPDATE.
--    Пишет в отдельную таблицу MeltsAuditLog.

-- Таблица расширенного аудита плавок
CREATE TABLE MeltsAuditLog (
   AuditId        INT          IDENTITY(1,1) NOT NULL PRIMARY KEY,
   ActionType     NVARCHAR(10)  NOT NULL CHECK (ActionType IN
('DELETE','UPDATE')),
   DatabaseUser   NVARCHAR(128) NOT NULL,   -- текущий пользователь
БД
   AppUser        NVARCHAR(128) NOT NULL,   -- системный логин
   AffectedMeltId INT           NULL,
   OldData        NVARCHAR(MAX) NULL,       -- JSON строки ДО изменения
   NewData        NVARCHAR(MAX) NULL,       -- JSON строки ПОСЛЕ
изменения
   AuditDateTime  DATETIME2     NOT NULL DEFAULT SYSDATETIME(),
   HostName       NVARCHAR(128) NOT NULL DEFAULT HOST_NAME(),
   AppName        NVARCHAR(128) NOT NULL DEFAULT APP_NAME()
);
GO

-- Индекс для быстрого поиска по дате и пользователю
CREATE INDEX IX_MeltsAuditLog_DateTime   ON MeltsAuditLog
(AuditDateTime DESC);
CREATE INDEX IX_MeltsAuditLog_ActionUser ON MeltsAuditLog
(ActionType, DatabaseUser);
GO

-- Триггер: аудит DELETE и UPDATE по таблице Melts
-- Задание 1 — только таблица Melts
-- Задание 2 — фильтр по пользователю/роли: OperatorRole и AdminChem
-- Задание 3 — только DELETE и UPDATE (INSERT намеренно пропускаем)
CREATE OR ALTER TRIGGER TRG_Melts_Audit
ON Melts
AFTER DELETE, UPDATE
AS
BEGIN
   SET NOCOUNT ON;
```

```
-- Задание 2: пропускаем событие, если пользователь не входит в нужные роли
IF IS_ROLEMEMBER('OperatorRole') = 0
  AND IS_ROLEMEMBER('ChemAdminRole') = 0
  AND IS_ROLEMEMBER('db_ddladmin') = 0   -- AdminChem состоит в db_ddladmin
  AND SUSER_SNAME() NOT IN ('AdminChem', 'Operator')
BEGIN
   RETURN;
END;

DECLARE @Action NVARCHAR(10);

-- Задание 3: определяем тип операции; INSERT игнорируем
IF EXISTS(SELECT 1 FROM DELETED) AND EXISTS(SELECT 1 FROM INSERTED)
   SET @Action = 'UPDATE';
ELSE IF EXISTS(SELECT 1 FROM DELETED) AND NOT EXISTS(SELECT 1 FROM INSERTED)
   SET @Action = 'DELETE';
ELSE
   RETURN; -- INSERT — выходим

DECLARE @OldJson NVARCHAR(MAX) = (
   SELECT MeltId, GradeId, EmployeeId, DepartmentId, FurnaceId,
         Date, Note, QuantityInTons
   FROM DELETED
   FOR JSON PATH
);

DECLARE @NewJson NVARCHAR(MAX) = (
   SELECT MeltId, GradeId, EmployeeId, DepartmentId, FurnaceId,
         Date, Note, QuantityInTons
   FROM INSERTED
   FOR JSON PATH
);

INSERT INTO MeltsAuditLog
   (ActionType, DatabaseUser, AppUser, AffectedMeltId, OldData, NewData)
SELECT
   @Action,
   USER_NAME(),
   SUSER_SNAME(),
   COALESCE(d.MeltId, i.MeltId),
```

```
        @OldJson,
        @NewJson
    FROM (SELECT TOP 1 MeltId FROM DELETED  UNION ALL SELECT
NULL) d(MeltId)
    FULL JOIN (SELECT TOP 1 MeltId FROM INSERTED UNION ALL
SELECT NULL) i(MeltId) ON 1=1
    WHERE COALESCE(d.MeltId, i.MeltId) IS NOT NULL;
END;
GO


-- 4. ЗАДАНИЕ 4: Найти все события за последние 24 часа
--    — из таблицы ChangeLog (общий журнал)
--    — и из MeltsAuditLog (расширенный аудит Melts)

-- Запрос: события из общего ChangeLog за 24 ч
SELECT
    LogId,
    ActionType,
    TableName,
    ChangedRowData,
    ChangeDateTime
FROM ChangeLog
WHERE ChangeDateTime >= DATEADD(HOUR, -24, GETDATE())
ORDER BY ChangeDateTime DESC;
```

Результаты | Сообщения

	LogId	ActionType	TableName	ChangedRowData	ChangeDateTime
1	9	INSERT	MeltElements	{"MeltElementId":20,"MeltId":10,"ElementId":7,"Quant...	2026-04-10 21:10:06.423
2	8	INSERT	Melts	{"MeltId":20,"GradeId":10,"EmployeeId":10,"Departm...	2026-04-10 21:10:06.420
3	7	INSERT	GradeElements	{"GradeElementId":20,"GradeId":10,"ElementId":1,"Lo...	2026-04-10 21:10:06.417
4	6	INSERT	Furnaces	{"FurnaceId":10,"FurnaceName":"FurnaceJ","Depart...	2026-04-10 21:10:06.413
5	4	INSERT	Employees	{"EmployeeId":10,"FullName":"Emma White","Depart...	2026-04-10 21:10:06.410
6	5	UPDATE	Departments	{"DepartmentId":7,"DepartmentName":"Rolling","Hea...	2026-04-10 21:10:06.410
7	3	INSERT	Departments	{"DepartmentId":10,"DepartmentName":"Logistics"},{"...	2026-04-10 21:10:06.407
8	2	INSERT	Grades	{"GradeId":10,"GradeName":"SpecialGrade2"},{"Grad...	2026-04-10 21:10:06.403
9	1	INSERT	ChemicalElements	{"ElementId":10,"ElementName":"Molybdenum","Type...	2026-04-10 21:10:06.400

```
-- Запрос: события из расширенного аудита Melts за 24 ч
SELECT
    AuditId,
    ActionType,
    DatabaseUser,
    AppUser,
    AffectedMeltId,
    OldData,
```

```
        NewData,
        AuditDateTime,
        HostName,
        AppName
    FROM MeltsAuditLog
    WHERE AuditDateTime >= DATEADD(HOUR, -24, SYSDATETIME())
    ORDER BY AuditDateTime DESC;
    GO
```

149 %

Результаты | Сообщения

	AuditId	ActionType	DatabaseUser	AppUser	AffectedMeltId	OldData	NewData	AuditDateTime	HostName	AppName
1	1	UPDATE	dbo	nwin\maqui	22	[{"MeltId":22,"GradeId":12,"EmployeeId":1,"Depart...	[{"MeltId":22,"GradeId":12,"EmployeeId":1,"DepartmentId":1,"FurnaceId":2,"Date":"2024-10-04","Note":"T1Z","QuantityInTons":12.12}]	2026-04-10 21:46:34.0260916	NWIN	Microsoft SQL Server Management Studio
2	2	UPDATE	dbo	nwin\maqui	22	[{"MeltId":22,"GradeId":12,"EmployeeId":1,"Depart...	[{"MeltId":22,"GradeId":12,"EmployeeId":1,"DepartmentId":1,"FurnaceId":2,"Date":"2024-10-04","Note":"T1Z","QuantityInTons":12.12}]	2026-04-10 21:46:34.0260916	NWIN	Microsoft SQL Server Management Studio
3	3	UPDATE	dbo	nwin\maqui	22	[{"MeltId":22,"GradeId":12,"EmployeeId":1,"Depart...	[{"MeltId":22,"GradeId":12,"EmployeeId":1,"DepartmentId":1,"FurnaceId":2,"Date":"2024-10-04","Note":"T1Z","QuantityInTons":12.12}]	2026-04-10 21:46:34.0260916	NWIN	Microsoft SQL Server Management Studio

```
    -- 5. ЗАДАНИЕ 5: Найти действия пользователя, связанные
    --    с изменением важных (чувствительных) полей.
    --    Чувствительные поля: QuantityInTons, GradeId, Note в Melts;
    --    LowerLimitQuantity / UpperLimitQuantity в GradeElements.

    -- Представление: изменения критичных полей плавок (QuantityInTons,
GradeId, Note)
    CREATE OR ALTER VIEW VW_Audit_SensitiveFieldChanges AS
    SELECT
        mal.AuditId,
        mal.AuditDateTime,
        mal.DatabaseUser,
        mal.AppUser,
        mal.ActionType,
        mal.AffectedMeltId,
        -- Сравниваем JSON старых и новых данных через OPENJSON
        old_v.QuantityInTons AS OldQuantity,
        new_v.QuantityInTons AS NewQuantity,
        old_v.GradeId        AS OldGradeId,
        new_v.GradeId        AS NewGradeId,
        old_v.Note           AS OldNote,
        new_v.Note           AS NewNote,
        CASE
            WHEN old_v.QuantityInTons <> new_v.QuantityInTons THEN
'QuantityInTons changed'
            WHEN old_v.GradeId <> new_v.GradeId              THEN 'GradeId changed'
            WHEN ISNULL(old_v.Note,'') <> ISNULL(new_v.Note,'') THEN 'Note
changed'
            ELSE 'Other field changed'
        END AS ChangedField
    FROM MeltsAuditLog mal
    CROSS APPLY (
```

```
        SELECT TOP 1
            TRY_CAST(JSON_VALUE(value, '$.QuantityInTons') AS
DECIMAL(10,2)) AS QuantityInTons,
            TRY_CAST(JSON_VALUE(value, '$.GradeId')       AS INT)          AS
GradeId,
            JSON_VALUE(value, '$.Note')                                    AS Note
        FROM OPENJSON(ISNULL(mal.OldData, '[]'))
    ) old_v
    CROSS APPLY (
        SELECT TOP 1
            TRY_CAST(JSON_VALUE(value, '$.QuantityInTons') AS
DECIMAL(10,2)) AS QuantityInTons,
            TRY_CAST(JSON_VALUE(value, '$.GradeId')       AS INT)          AS
GradeId,
            JSON_VALUE(value, '$.Note')                                    AS Note
        FROM OPENJSON(ISNULL(mal.NewData, '[]'))
    ) new_v
    WHERE mal.ActionType = 'UPDATE'
      AND (
            old_v.QuantityInTons <> new_v.QuantityInTons
         OR old_v.GradeId        <> new_v.GradeId
         OR ISNULL(old_v.Note,'') <> ISNULL(new_v.Note,'')
      );
    GO
```

nwin.chemlabtables...sitiveFieldChanges | nwin.chemlabtables - dbo.Melts | nwin.chemlabtable...o.SecurityAuditLog | nwin.chemlabtable...dbo.GradeElements

AuditId	AuditDateTime	DatabaseUser	AppUser	ActionType	AffectedMeltId	OldQuantity	NewQuantity	OldGradeId	NewGradeId	OldNote	NewNote	ChangedField
4	2026-04-17 20:3...	dbo	sa	UPDATE	22	12,12	12,12	12	12	T12	неработает	Note changed
5	2026-04-17 20:3...	dbo	sa	UPDATE	22	12,12	12,12	12	12	T12	неработает	Note changed
6	2026-04-17 20:3...	dbo	sa	UPDATE	22	12,12	12,12	12	12	T12	неработает	Note changed
NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL

```
    -- Запрос: история изменений пределов состава по GradeElements из
ChangeLog
    SELECT
        LogId,
        ActionType,
        ChangedRowData,
        ChangeDateTime,
        USER_NAME() AS CurrentUser
    FROM ChangeLog
    WHERE TableName = 'GradeElements'
      AND ActionType IN ('UPDATE','DELETE')
    ORDER BY ChangeDateTime DESC;
    GO
```

Результаты | Сообщения

	LogId	ActionType	ChangedRowData	ChangeDateTime	CurrentUser
1	16	UPDATE	{"GradeElementId":22,"GradeId":12,"ElementId":12,"LowerLimitQuantity":12.12,"UpperLimitQuantity":12.13},{"GradeElementId":22,"GradeId":12,"ElementId":12,"LowerLimitQuantity":12.00,"UpperLimitQuantity":12.12}	2026-04-10 21:45:15.850	dbo
2	15	UPDATE	{"GradeElementId":21,"GradeId":11,"ElementId":11,"LowerLimitQuantity":11.11,"UpperLimitQuantity":11.12},{"GradeElementId":21,"GradeId":11,"ElementId":11,"LowerLimitQuantity":11.00,"UpperLimitQuantity":11.11}	2026-04-10 21:45:08.367	dbo

```
-- 6. ЗАДАНИЕ 6: Найти все случаи неудачного входа.
--
--    SQL Server хранит неудачные логины в системном журнале
--    событий Windows и в SQL Server Error Log.
--    Средствами T-SQL читаем через системную ХП и SQL Audit.

-- Чтение журнала ошибок SQL Server (неудачные логины — Severity 14)
-- Создаём вспомогательную таблицу для результатов
IF OBJECT_ID('tempdb..#LoginErrors') IS NOT NULL DROP TABLE
#LoginErrors;
CREATE TABLE #LoginErrors (
   LogDate    DATETIME,
   ProcessInfo NVARCHAR(100),
   [Text]     NVARCHAR(MAX)
);

-- Читаем текущий лог ошибок SQL Server
INSERT INTO #LoginErrors
EXEC xp_readerrorlog 0, 1, N'Login failed';

-- Выборка неудачных попыток входа
SELECT
   LogDate            AS FailedLoginTime,
   ProcessInfo,
   [Text]             AS ErrorDetail
FROM #LoginErrors
ORDER BY LogDate DESC;

DROP TABLE #LoginErrors;
GO


GO


-- 7. ЗАДАНИЕ 7: Отдельный аудит для пользователей
--    с административными правами (AdminChem / db_ddladmin).
--    Используем SQL Server Audit (SERVER AUDIT + DATABASE AUDIT).

USE master;
GO

-- Создаём Server Audit (записываем в файл; при необходимости замените
путь)
```

```
IF NOT EXISTS (SELECT 1 FROM sys.server_audits WHERE name =
'AdminChem_ServerAudit')
BEGIN
   CREATE SERVER AUDIT AdminChem_ServerAudit
   TO FILE (
      FILEPATH = N'C:\AuditLogs\',
      MAXSIZE   = 50 MB,
      MAX_FILES = 5,
      RESERVE_DISK_SPACE = OFF
   )
   WITH (
      QUEUE_DELAY    = 1000,
      ON_FAILURE     = CONTINUE,
      AUDIT_GUID     = NEWID(),
   );
END;
GO

ALTER SERVER AUDIT AdminChem_ServerAudit WITH (STATE = ON);
GO

USE chemlabtables;
GO

-- Database Audit Specification: аудит DDL и DML от имени AdminChem
IF NOT EXISTS (SELECT 1 FROM sys.database_audit_specifications WHERE
name = 'AuditSpec_AdminChem')
BEGIN
   CREATE DATABASE AUDIT SPECIFICATION AuditSpec_AdminChem
   FOR SERVER AUDIT AdminChem_ServerAudit
   ADD (SELECT, INSERT, UPDATE, DELETE ON dbo.Melts         BY
AdminChem),
   ADD (SELECT, INSERT, UPDATE, DELETE ON dbo.MeltElements   BY
AdminChem),
   ADD (SELECT, INSERT, UPDATE, DELETE ON dbo.ChangeLog      BY
AdminChem),
   ADD (SELECT, INSERT, UPDATE, DELETE ON dbo.Grades         BY
AdminChem),
   ADD (SELECT, INSERT, UPDATE, DELETE ON dbo.ChemicalElements BY
AdminChem),
   ADD (SCHEMA_OBJECT_CHANGE_GROUP)    -- все DDL-операции
   WITH (STATE = ON);
END;
GO
```

```
-- Запрос к файлу аудита AdminChem (после включения)
-- SELECT event_time, database_principal_name, object_name, action_id,
succeeded
-- FROM
sys.fn_get_audit_file('C:\AuditLogs\AdminChem_ServerAudit*.sqlaudit', DEFAULT,
DEFAULT)
-- ORDER BY event_time DESC;
GO


-- 8. ЗАДАНИЕ 8: Аудит изменений ролей и прав доступа.
--    Таблица SecurityAuditLog + триггер на DDL-события уровня БД.

USE chemlabtables;
GO

-- Таблица аудита безопасности
CREATE TABLE SecurityAuditLog (
   SecurityAuditId INT          IDENTITY(1,1) NOT NULL PRIMARY KEY,
   EventType      NVARCHAR(100) NOT NULL,   -- ADD_ROLE_MEMBER,
GRANT, REVOKE, DENY, ...
   ObjectName     NVARCHAR(256) NULL,
   SchemaName     NVARCHAR(256) NULL,
   LoginName      NVARCHAR(256) NOT NULL,
   DatabaseUser   NVARCHAR(256) NOT NULL,
   EventXml       XML           NULL,       -- полный XML события
   EventDateTime  DATETIME2     NOT NULL DEFAULT SYSDATETIME()
);
GO

-- DDL-триггер на уровне базы данных: перехватывает изменения прав
CREATE OR ALTER TRIGGER TRG_SecurityAudit
ON DATABASE
FOR
   ADD_ROLE_MEMBER,
   DROP_ROLE_MEMBER,
   GRANT_DATABASE,
   REVOKE_DATABASE,
   DENY_DATABASE,
   CREATE_ROLE,
   DROP_ROLE,
   ALTER_ROLE,
   CREATE_USER,
```

```
        DROP_USER,
        ALTER_USER
    AS
    BEGIN
        SET NOCOUNT ON;
        DECLARE @EventData XML = EVENTDATA();

        INSERT INTO SecurityAuditLog
            (EventType, ObjectName, SchemaName, LoginName, DatabaseUser,
EventXml)
        VALUES (
            @EventData.value('(/EVENT_INSTANCE/EventType)[1]',
'NVARCHAR(100)'),
            @EventData.value('(/EVENT_INSTANCE/ObjectName)[1]',
'NVARCHAR(256)'),
            @EventData.value('(/EVENT_INSTANCE/SchemaName)[1]',
'NVARCHAR(256)'),
            @EventData.value('(/EVENT_INSTANCE/LoginName)[1]',
'NVARCHAR(256)'),
            @EventData.value('(/EVENT_INSTANCE/UserName)[1]',
'NVARCHAR(256)'),
            @EventData
        );
    END;
    GO

    -- Запрос: все изменения ролей/прав за всё время
    SELECT
        SecurityAuditId,
        EventType,
        ObjectName,
        LoginName,
        DatabaseUser,
        EventDateTime
    FROM SecurityAuditLog
    ORDER BY EventDateTime DESC;
    GO
```

nwin.chemlabtable...o.SecurityAuditLog | SQLQuery2.sql - NWI...labtables (sa (80))* | nwin.chemlabtables...sitiveFieldChanges | nwin.chemlabtables - dbo.Melts | nwin.chemlabtable...dbo.GradeElements

SecurityAuditId	EventType	ObjectName	SchemaName	LoginName	DatabaseUser	EventXml	EventDateTime
1	GRANT_DATABASE	AuditMethodComparison	dbo	sa	dbo	<EVENT_INSTANCE><EventType>GRANT_DATABASE</EventType>...	2026-04-17 2026-04
2	GRANT_DATABASE	CriticalEventsPriority	dbo	sa	dbo	<EVENT_INSTANCE><EventType>GRANT_DATABASE</EventType>...	2026-04-17 20:4...
NULL	NULL	NULL	NULL	NULL	NULL	NULL	NULL

```
    -- 9. ЗАДАНИЕ 9: Сравнение SQL Server Audit vs Триггеры аудита
```

```
--    Реализовано как справочное представление с комментариями.

-- Справочная таблица с описанием отличий
CREATE TABLE AuditMethodComparison (
    CriteriaId  INT          IDENTITY(1,1) NOT NULL PRIMARY KEY,
    Criteria    NVARCHAR(100) NOT NULL,
    TriggerAudit     NVARCHAR(500) NOT NULL,
    SQLServerAudit   NVARCHAR(500) NOT NULL
);
GO

INSERT INTO AuditMethodComparison (Criteria, TriggerAudit,
SQLServerAudit) VALUES
('Механизм',
 'T-SQL триггер AFTER INSERT/UPDATE/DELETE — часть транзакции',
 'Встроенный движок SQL Server, работает вне транзакции пользователя'),
('Охват событий',
 'Только DML (INSERT, UPDATE, DELETE) на конкретной таблице',
 'DML + DDL + Login + Permission + любые серверные события'),
('Производительность',
 'Добавляет нагрузку к каждой транзакции; риск блокировок',
 'Асинхронная запись в файл или Windows Event Log — минимальная
нагрузка'),
('Защита журнала',
 'Таблица в БД — может быть изменена пользователем с нужными правами',
 'Файл .sqlaudit вне БД — труднее подделать; поддержка SQL Server Audit
signature'),
('Гибкость фильтрации',
 'Полная гибкость: WHERE, IS_ROLEMEMBER(), SUSER_SNAME() и т.д.',
 'WHERE predicate в AUDIT SPECIFICATION ограничен (нельзя вызывать
функции)'),
('Откат транзакции',
 'При ROLLBACK запись в ChangeLog тоже откатывается',
 'Событие аудита сохраняется даже при ROLLBACK транзакции'),
('Доступность данных',
 'SELECT из таблицы в той же БД — просто и привычно',
 'sys.fn_get_audit_file() — требует доступа к файловой системе сервера'),
('Поддержка SQL Server',
 'Все версии SQL Server',
 'SQL Server 2008+ (Enterprise/Developer для файлового аудита)'),
('Рекомендация',
 'Хорош для мониторинга бизнес-логики и изменений конкретных полей',
 'Предпочтителен для compliance (GDPR, ISO 27001) и аудита
безопасности');
```

```
GO

-- Просмотр сравнительной таблицы
SELECT Criteria, TriggerAudit, SQLServerAudit FROM
AuditMethodComparison;
GO
```

149 %

Результаты | Сообщения

	CriteriaId	Criteria	TriggerAudit	SQLServerAudit
1	1	Механизм	T-SQL триггер AFTER INSERT/UPDATE/DELETE – часть т...	Встроенный движок SQL Server, работает вне транзак...
2	2	Охват событий	Только DML (INSERT, UPDATE, DELETE) на конкретной та...	DML + DDL + Login + Permission + любые серверные со...
3	3	Производительность	Добавляет нагрузку к каждой транзакции; риск блокировок	Асинхронная запись в файл или Windows Event Log – ...
4	4	Защита журнала	Таблица в БД – может быть изменена пользователем с н...	Файл .sqlaudit вне БД – труднее подделать; поддержка...
5	5	Гибкость фильтрации	Полная гибкость: WHERE, IS_ROLEMEMBER(), SUSER_S...	WHERE predicate в AUDIT SPECIFICATION ограничен (...
6	6	Откат транзакции	При ROLLBACK запись в ChangeLog тоже откатывается	Событие аудита сохраняется даже при ROLLBACK тра...
7	7	Доступность данных	SELECT из таблицы в той же БД – просто и привычно	sys.fn_get_audit_file() – требует доступа к файловой сис...
8	8	Поддержка SQL Server	Все версии SQL Server	SQL Server 2008+ (Enterprise/Developer для файлового ...
9	9	Рекомендация	Хорош для мониторинга бизнес-логики и изменений конкр...	Предпочтителен для compliance (GDPR, ISO 27001) и ау...

```
-- 10. ЗАДАНИЕ 10: Определить критичные события для БД
--     chemlabtables (металлургическое производство).
--     Представление + приоритетная таблица событий.

CREATE TABLE CriticalEventsPriority (
    PriorityId   INT          IDENTITY(1,1) NOT NULL PRIMARY KEY,
    Priority     TINYINT      NOT NULL,          -- 1 = наивысший
    EventCategory NVARCHAR(50) NOT NULL,
    EventDescription NVARCHAR(300) NOT NULL,
    AffectedTable   NVARCHAR(100) NOT NULL,
    WhyItMatters    NVARCHAR(400) NOT NULL,
    RecommendedResponse NVARCHAR(300) NOT NULL
);
GO

INSERT INTO CriticalEventsPriority
    (Priority, EventCategory, EventDescription, AffectedTable, WhyItMatters,
RecommendedResponse)
VALUES
(1, 'Состав плавки',
 'Изменение QuantityInTons или GradeId существующей плавки',
 'Melts',
 'Прямое влияние на качество продукции и финансовый учёт;
фальсификация документов',
 'Немедленное уведомление начальника цеха; блокировка операции без
согласования'),
(2, 'Химический состав',
 'Удаление или изменение MeltElements (доля элементов в плавке)',
```

```
    'MeltElements',
    'Изменение состава задним числом скрывает несоответствие стандартам (ГОСТ/EN)',
    'Запрет UPDATE/DELETE без роли ChemAdminRole; аудит каждой операции'),
   (3, 'Нормы марки стали',
    'Изменение LowerLimitQuantity / UpperLimitQuantity в GradeElements',
    'GradeElements',
    'Расширение допусков позволяет «легализовать» бракованные плавки',
    'Требовать подтверждение от двух администраторов (4-eyes principle)'),
   (4, 'Права доступа',
    'GRANT/REVOKE/DENY к таблицам Melts, MeltElements, GradeElements',
    'SecurityAuditLog',
    'Несанкционированное расширение прав может дать доступ к изменению данных',
    'DDL-триггер TRG_SecurityAudit уже активен; ежедневный просмотр SecurityAuditLog'),
   (5, 'Аутентификация',
    'Повторные неудачные попытки входа (>5 за 10 мин) от одного логина',
    'SQL Server Error Log',
    'Признак брутфорс-атаки или компрометации учётных данных',
    'Блокировка логина после N неудач; уведомление DBA'),
   (6, 'Справочники',
    'Удаление записей из Grades или ChemicalElements',
    'Grades, ChemicalElements',
    'Удаление марки стали делает исторические плавки «сиротами»',
    'ON DELETE NO ACTION + обязательный аудит DELETE'),
   (7, 'DDL-изменения',
    'ALTER/DROP таблиц, триггеров, процедур в chemlabtables',
    'Все объекты схемы',
    'Изменение структуры БД может нарушить целостность аудита',
    'Аудит SCHEMA_OBJECT_CHANGE_GROUP через SQL Server Audit (задание 7)');
GO

-- Итоговый отчёт о критичных событиях
SELECT
    Priority,
    EventCategory,
    EventDescription,
    AffectedTable,
    WhyItMatters,
    RecommendedResponse
FROM CriticalEventsPriority
```

ORDER BY Priority;
GO

149 %

Результаты | Сообщения

	Priority	EventCategory	EventDescription	AffectedTable	WhyItMatters	RecommendedResponse
1	1	Состав плавки	Изменение QuantityInTons или GradeId существующей...	Melts	Прямое влияние на качество продукции и финансовый...	Немедленное уведомление начальника цеха; блокировка ...
2	2	Химический состав	Удаление или изменение MeltElements (доля элемент...	MeltElements	Изменение состава задним числом скрывает несоотв...	Запрет UPDATE/DELETE без роли ChemAdminRole; аудит к...
3	3	Нормы марки стали	Изменение LowerLimitQuantity / UpperLimitQuantity в Gr...	GradeElements	Расширение допусков позволяет «легализовать» брак...	Требовать подтверждение от двух администраторов (4-eye...
4	4	Права доступа	GRANT/REVOKE/DENY к таблицам Melts, MeltElement...	SecurityAuditLog	Несанкционированное расширение прав может дать д...	DDL-триггер TRG_SecurityAudit уже активен; ежедневный ...
5	5	Аутентификация	Повторные неудачные попытки входа (>5 за 10 мин) о...	SQL Server Error Log	Признак брутфорс-атаки или компрометации учётных ...	Блокировка логина после N неудач; уведомление DBA
6	6	Справочники	Удаление записей из Grades или ChemicalElements	Grades, ChemicalElements	Удаление марки стали делает исторические плавки «с...	ON DELETE NO ACTION + обязательный аудит DELETE
7	7	DDL-изменения	ALTER/DROP таблиц, триггеров, процедур в chemlabt...	Все объекты схемы	Изменение структуры БД может нарушить целостност...	Аудит SCHEMA_OBJECT_CHANGE_GROUP через SQL Serv...

Контрольные вопросы

1. Что такое SQL Server Audit?

SQL Server Audit — это встроенный механизм SQL Server (начиная с версии 2008) для отслеживания и логирования событий на уровне экземпляра сервера и отдельных баз данных. Он позволяет фиксировать действия пользователей, изменения конфигурации, доступ к объектам, операции DML/DDL и многое другое.

Аудит построен на базе Extended Events, но имеет удобный интерфейс и дополнительные возможности (запись в Windows Security Log, возможность принудительного shutdown сервера при ошибке записи и т.д.). Он используется для соответствия требованиям compliance (PCI DSS, GDPR, HIPAA и др.), расследования инцидентов безопасности и мониторинга активности.

2. Чем отличается Audit от Audit Specification?

SQL Server Audit (просто «Audit») — это контейнер (объект на уровне экземпляра сервера). Он определяет куда писать логи (файл .sqlaudit, Windows Application Log или Security Log), размер файлов, политику ротации (max_files, max_size), фильтры и поведение при ошибке записи.

Audit Specification (Server Audit Specification или Database Audit Specification) — это список событий, которые нужно фиксировать. Specification «привязывается» к конкретному Audit-объекту и определяет что именно аудитировать (группы событий или отдельные действия).

Один Audit может иметь одну Server Audit Specification и несколько Database Audit Specifications (по одной на базу). Без Audit Specification ничего не будет записываться, даже если Audit включён.

3. Какие события можно фиксировать?

SQL Server Audit позволяет аудитировать два основных уровня:

Server-level (через Server Audit Specification):

Входы/выходы (SUCCESSFUL_LOGIN_GROUP, FAILED_LOGIN_GROUP)

Изменения серверных ролей, разрешений, конфигурации

Создание/удаление баз данных, backup/restore

Изменения аудита (AUDIT_CHANGE_GROUP)

DBCC-команды, SERVER_OBJECT_CHANGE_GROUP и др.

Database-level (через Database Audit Specification, доступно в Enterprise/Developer edition):

DML: SELECT, INSERT, UPDATE, DELETE на конкретных таблицах/схемах

DDL: CREATE/ALTER/DROP объектов

Изменения разрешений, владельцев, ролей в базе

SCHEMA_OBJECT_ACCESS_GROUP, DATABASE_OBJECT_CHANGE_GROUP и т.д.

Можно аудитировать как группы событий (Action Groups), так и отдельные действия. С SQL Server 2012+ поддерживаются фильтры (WHERE) прямо в Audit.

4. Где могут храниться результаты аудита?

Результаты аудита (target) можно записывать в три места:

Файл (наиболее рекомендуемый) — бинарные файлы с расширением .sqlaudit. Поддерживается ротация, ограничение размера и количества файлов.

Windows Application Log (журнал приложений).

Windows Security Log (журнал безопасности) — самый защищённый вариант, но требует дополнительных прав (Audit Object Access policy в Windows).

Файлы можно хранить на локальном диске, сетевой шаре или в Azure Blob Storage (в облачных вариантах). Рекомендуется писать на отдельный сервер/диск, чтобы злоумышленник не смог удалить логи.

5. Что делает SUCCESSFUL_LOGIN_GROUP?

Эта группа событий фиксирует успешные попытки входа в SQL Server (логин пользователя).

Событие поднимается при каждой успешной аутентификации (включая pooled connections). Полезно для мониторинга нормальной активности, выявления необычных паттернов входов и соответствия требованиям аудита.

6. Что делает FAILED_LOGIN_GROUP?

Эта группа фиксирует неуспешные попытки входа (failed logon attempts).

Очень важна для обнаружения атак brute-force, подбора паролей или попыток входа скомпрометированными учётными данными. Рекомендуется всегда включать вместе с SUCCESSFUL_LOGIN_GROUP.

7. Для чего используется sys.fn_get_audit_file?

Это табличная функция (table-valued function), которая читает содержимое файлов аудита (.sqlaudit) и возвращает данные в виде таблицы.

Используется для просмотра, анализа и выгрузки логов с помощью T-SQL. Пример:

SQL

```
SELECT event_time, action_id, succeeded, server_principal_name,
    database_name, object_name, statement
FROM sys.fn_get_audit_file('C:\AuditLogs\*.sqlaudit', DEFAULT, DEFAULT)
WHERE server_principal_name = 'DOMAIN\User'
ORDER BY event_time DESC;
```

Можно указывать маску файлов, начальный файл и смещение. В SSMS также есть «View Audit Logs», но функция даёт больше гибкости для фильтрации и отчётов.

8. Какие поля наиболее полезны при расследовании инцидентов?

Самые ценные поля в результатах аудита:

event_time — точное время события

server_principal_name / server_principal_id — кто выполнил действие (логин)

database_name — в какой базе произошло событие

schema_name / object_name — над каким объектом (таблица, процедура и т.д.)

action_id — код действия (например, SL = SELECT, IN = INSERT, LGIF = Login)

statement — полный текст SQL-запроса/команды

succeeded — успешно ли выполнено (0/1)

client_ip / application_name / host_name — откуда пришло (IP, приложение, компьютер)

additional_information — дополнительная информация (например, XML с деталями pooled connection)

session_id, duration и др.

Эти поля позволяют быстро восстановить картину: кто, когда, что сделал и откуда.

9. Как найти действия конкретного пользователя?

Самый простой способ — запрос через sys.fn_get_audit_file с фильтром по server_principal_name (или database_principal_name):

SQL

```
SELECT event_time, action_id, succeeded, database_name,
       object_name, statement, client_ip
FROM sys.fn_get_audit_file('D:\Audit\*.sqlaudit', DEFAULT, DEFAULT)
WHERE server_principal_name = 'DOMAIN\Ivanov'   -- или 'sa', 'login_name'
ORDER BY event_time DESC;
```

Можно добавить фильтры по дате, action_id, database_name и т.д.

Если нужно аудитировать только одного пользователя заранее — используйте фильтр в самом Audit-объекте (WHERE clause, начиная с SQL Server 2012).

10. Чем SQL Server Audit лучше обычных триггеров?

Преимущества SQL Server Audit перед триггерами:

Производительность — значительно ниже overhead (работает на базе Extended Events, а не внутри каждой транзакции).

Централизованное управление — один механизм для всего сервера/базы, не нужно писать триггер на каждую таблицу.

Аудит на уровне сервера — логины, изменения конфигурации, серверные роли (триггеры этого не ловят).

Защита логов — можно писать в Security Log, который сложнее подделать/удалить.

Гибкие фильтры и группы событий — легко включать/выключать группы без изменения кода.

Соответствие compliance — официальный инструмент Microsoft, легче проходить аудиты.

Не влияет на логику приложения — триггеры могут ломать сложные сценарии (особенно с IDENTITY, триггерами и т.д.).

Когда триггеры всё-таки нужны: если требуется хранить старые и новые значения строк (before/after) в детализированном виде — Audit обычно не сохраняет полные образы данных (кроме отдельных случаев). Для этого лучше использовать Change Data Capture (CDC), Temporal Tables или кастомные триггеры